

AUDITORÍA CARTERAPRO RISK LAB

**Auditoría Técnica Integral y Seguridad de Software:
Sistema CarteraPro
Risk Lab**

Xiomara Ocampo Hurtado,

Carlos Augusto Aranzazu,

y María Luisa Londoño

Tendencias en Ingeniería de Software

Carlos Andres Jaramillo

Universidad Alexander von Humboldt
Facultad de Ingeniería y Ciencias Básicas
Ingeniería de Software

9 de junio de 2026

Índice

Introducción	3
Estado General del Sistema	3
Principales Riesgos Identificados	3
Hallazgos Más Relevantes	3
Inyección SQL	3
Credenciales Expuestas Públicamente	3
Ejecución Remota de Comandos	4
Dependencias con Vulnerabilidades Críticas	4
Nivel General de Calidad y Seguridad	4
Prioridades de Intervención	4
Conclusión Ejecutiva	4

Índice de cuadros

1.	Estado General del Sistema por Dimensiones	6
2.	Matriz de Riesgos Identificados y Priorizados	7
3.	Métricas de Calidad y Seguridad	8
4.	Plan de Intervención por Horizontes Temporales	9

Introducción

El sistema CarteraPro Risk Lab es una aplicación web de gestión de cartera y clientes desarrollada con Node.js/Express en el backend y React en el frontend. Tras realizar una auditoría técnica integral utilizando análisis estático (SonarQube), análisis dinámico (OWASP ZAP) y revisión manual del código fuente, se elaboró el presente informe ejecutivo dirigido a la Dirección de Tecnología (CTO).

Estado General del Sistema

En términos generales, el sistema presenta vulnerabilidades de seguridad críticas que podrían ser explotadas por un atacante con conocimientos básicos, sin necesidad de herramientas especializadas. La ausencia total de pruebas automatizadas representa un riesgo operacional significativo ante cualquier cambio futuro en el código.

Principales Riesgos Identificados

Los siguientes riesgos fueron identificados como prioritarios durante la auditoría, abarcando desde vulnerabilidades críticas de seguridad hasta problemas de calidad de código y dependencias.

Hallazgos Más Relevantes

Inyección SQL

La funcionalidad de inicio de sesión construye las consultas a la base de datos concatenando directamente los datos ingresados por el usuario, sin ningún tipo de validación o sanitización. Esto permite a cualquier persona acceder al sistema completo sin necesidad de conocer ninguna contraseña, mediante una técnica estándar de inyección SQL. Un atacante podría acceder a toda la información de clientes, facturas y soportes de pago, modificar registros o eliminar la base de datos completa.

Credenciales Expuestas Públicamente

El sistema publica activamente las credenciales de administrador (usuario admin, contraseña admin123) en la respuesta del endpoint principal de la API, accesible sin autenticación desde cualquier navegador. Adicionalmente, el secreto utilizado para firmar tokens de sesión está configurado con el valor por defecto de desarrollo.

Cualquier persona con acceso a la URL del sistema obtiene automáticamente credenciales de administrador completo.

Ejecución Remota de Comandos

El módulo de administración contiene funcionalidad que permite ejecutar comandos del sistema operativo del servidor. Esta capacidad, combinada con las vulnerabilidades de autenticación descritas anteriormente, constituye un vector de compromiso total del servidor.

Dependencias con Vulnerabilidades Críticas

El sistema utiliza ocho bibliotecas de terceros con versiones que tienen vulnerabilidades de seguridad documentadas y públicamente conocidas. Entre ellas destaca jsonwebtoken, que permite ejecución remota de código, y axios, vulnerable a ataques de redirección de peticiones.

Nivel General de Calidad y Seguridad

La revisión métrica obtenida de SonarQube y OWASP ZAP ilustra el volumen de deuda técnica y brechas de seguridad.

Prioridades de Intervención

Se recomienda el siguiente plan de intervención estructurado en tres horizontes temporales.

Conclusión Ejecutiva

El sistema CarteraPro Risk Lab presenta un perfil de riesgo de seguridad crítico que requiere intervención inmediata antes de cualquier despliegue en un entorno productivo o con datos reales de clientes. Las vulnerabilidades identificadas no son teóricas; son explotables en su estado actual por cualquier persona con conocimientos básicos de seguridad web.

La combinación de inyección SQL en el módulo de autenticación, credenciales de administrador publicadas abiertamente y ausencia total de cifrado de contraseñas representa un riesgo existencial para la confidencialidad, integridad y disponibilidad de los datos gestionados por el sistema.

Se recomienda encarecidamente no poner este sistema en producción hasta que las vulnerabilidades de prioridad inmediata hayan sido corregidas y verificadas mediante una nueva auditoría de seguridad. Este informe fue elaborado en el marco de la materia SOF805 de la Universidad Alexander von Humboldt, Armenia, Quindío. Las pruebas se realizaron exclusivamente sobre el entorno de laboratorio suministrado.

Cuadro 1*Estado General del Sistema por Dimensiones*

Dimensión	Calificación	Nivel de Riesgo
Seguridad	E (Deficiente)	CRÍTICO
Fiabilidad	A (Satisfactoria)	BAJO
Mantenibilidad	A (Satisfactoria)	MEDIO
Calidad de Código	Deficiente	ALTO
Cobertura de Tests	0.0 % (Nula)	ALTO

Cuadro 2*Matriz de Riesgos Identificados y Priorizados*

ID	Hallazgo	Tipo	Severidad	Prioridad
SEC-001	Inyección SQL en autenticación y gestión de clientes	Seguridad	Crítica	Inmediata
SEC-002	Credenciales hardcodedas expuestas en API pública	Seguridad	Crítica	Inmediata
SEC-003	Token de sesión predecible sin firma criptográfica	Seguridad	Crítica	Inmediata
SEC-004	Ejecución de comandos OS desde endpoint de admin	Seguridad	Crítica	Inmediata
SEC-005	CORS irrestricto — acepta cualquier origen externo	Seguridad	Alta	Corto plazo
SEC-006	Contraseñas almacenadas en texto plano	Seguridad	Crítica	Inmediata
SEC-007	Stack trace expuesto al cliente en errores HTTP 500	Seguridad	Alta	Corto plazo
DEP-001	8 dependencias con CVEs críticos conocidos	Dependencias	Alta	Corto plazo
SEC-008	Path Traversal en parámetros de rutas de archivos	Seguridad	Alta	Corto plazo
SEC-009	Headers HTTP revelan información del stack	Seguridad	Media	Corto plazo
SEC-010	Content Security Policy (CSP) no configurada	Seguridad	Media	Corto plazo
CAL-001	534 code smells — 0 % cobertura de pruebas	Calidad	Media	Mediano plazo

Cuadro 3*Métricas de Calidad y Seguridad*

Métricas de Calidad (SonarQube)	Métricas de Seguridad (OWASP ZAP + SAST)
2.169 líneas de código analizadas	11 alertas DAST detectadas por ZAP
534 code smells (50 BLOCKER, 484 CRITICAL)	13 Security Hotspots pendientes de revisión
Complejidad ciclomática: 291	6 vulnerabilidades críticas identificadas
Cobertura de pruebas: 0 %	8 dependencias con CVEs conocidos
Duplicación de código: 0.9 %	Categorías OWASP afectadas: A01 a A09

Cuadro 4*Plan de Intervención por Horizontes Temporales*

Horizonte	Acciones	Esfuerzo
Inmediato (0–2 semanas)	Eliminar SQL Injection, cambiar credenciales, implementar hashing, revocar tokens.	Alto
Corto Plazo (2–8 semanas)	Restringir CORS, compilar frontend, actualizar dependencias, sanitizar errores, aplicar Rate Limiting y CSP.	Medio
Mediano Plazo (2–6 meses)	Implementar suite de pruebas, refactorizar código, establecer pipeline CI/CD, auditoría de recertificación.	Alto